

VULNERABILITY ASSESSMENT & PENETRATION TEST REPORT

Target System: DC-1 (VulnHub Lab Environment)

Prepared by: Santhosh
RedTeam Hacker Academy — CPT V4 Programme
Report Date: 29 September 2026

Table of Contents

S.No	Content	Page. No
1.	Executive Summary	1
2.	Scope	1
3.	Risk Rating	2
4.	Methodology	2
5.	Findings	5
6.	Remediation	13
7.	Conclusion	14
8.	Appendix-A	15
9.	Appendix-B	15

1. Executive Summary

This report documents an authenticated, black-box penetration test against the DC-1 lab target as part of the CPT V4 practical assessment. The objective was to evaluate the target's exposure to real-world attack techniques and to determine the maximum level of access an adversary could realistically obtain.

The assessment identified a critical remote code execution vulnerability in the target's content management system (Drupal, "Drupalgeddon2" / CVE-2018-7600) that permitted unauthenticated attackers to execute arbitrary commands on the host. This foothold was compounded by a world-readable configuration file containing live database credentials and a misconfigured SUID binary, which together allowed a complete escalation path from zero access to full root-level control of the operating system.

Overall Risk Rating: **CRITICAL** The combination of an internet-facing RCE vulnerability and a trivial local privilege-escalation path means a single unpatched component was sufficient to fully compromise the host. No compensating controls (WAF, restrictive file permissions, network segmentation) were observed to slow or detect the attack.

Key Statistics

- 7 findings identified — 2 Critical, 2 High, 2 Medium, 1 Low
- Time to initial foothold: under 90 minutes from first packet
- Time to full root compromise: under 3 hours, single tester, no prior credentials
- Highest-severity finding: CVE-2018-7600 (Drupalgeddon2), CVSS 9.8 (Critical)

2. Scope

Target Name	DC-1
Target Address	192.168.31.201 (lab NAT segment)
Engagement Type	Black-box network penetration test
Methodology Alignment	PTES Testing Guide (adapted for lab use)
Testing Window	29 September 2026, single continuous session
Tester(s)	Santhosh
Authorization	VulnHub — machine distributed for lawful security-training use

In Scope

- The DC-1 host, including all network services exposed on 192.168.31.201
- The Drupal web application and its underlying database
- Local privilege-escalation vectors reachable from an initial low-privileged shell

Out of Scope

- Denial-of-service testing
- Physical and social-engineering attack vectors
- Any host other than the designated lab target

3. Risk Rating

Findings in this report are rated using the Common Vulnerability Scoring System (CVSS v3.1) base score, translated into the qualitative ratings below to support prioritisation.

Rating	CVSS Range	Description
Critical	9.0 – 10.0	Trivially exploitable, unauthenticated, results in full system or data compromise.
High	7.0 – 8.9	Exploitable with minimal effort; leads to significant data exposure or partial system control.
Medium	4.0 – 6.9	Exploitable under specific conditions; limited impact or requires user interaction.
Low	0.1 – 3.9	Minor weakness with limited exploitability or impact.
Informational	0.0	Observation with no direct security impact; hardening opportunity.

4. Methodology

Rather than reproducing every command issued during testing, this section summarises the path an attacker followed from an unauthenticated network position to full root compromise. Full technical evidence for each step is provided against the corresponding finding in Section 5.

Step 1 — Discovery

Host discovery against the lab subnet identified DC-1 as a live target. A full-port service scan enumerated SSH (22), HTTP (80), and RPC-related services (111, 49392), and fingerprinted the web application as a Drupal 7 installation.

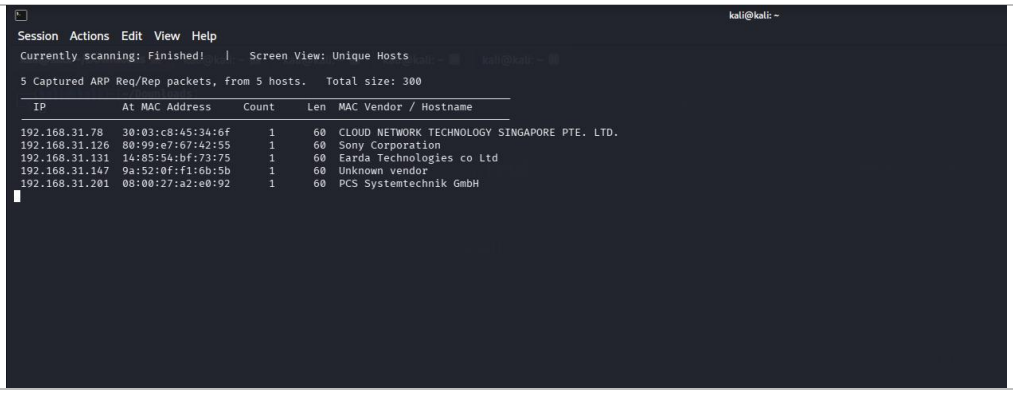


Figure 4.1 — Host discovery identifying the target on the lab subnet

Step 2 — Initial Access

Version fingerprinting of the Drupal installation was cross-referenced against public advisories, confirming exposure to Drupalgeddon2 (CVE-2018-7600). The vulnerability was weaponised via Metasploit, yielding an interactive shell in the context of the web server process without any prior authentication.

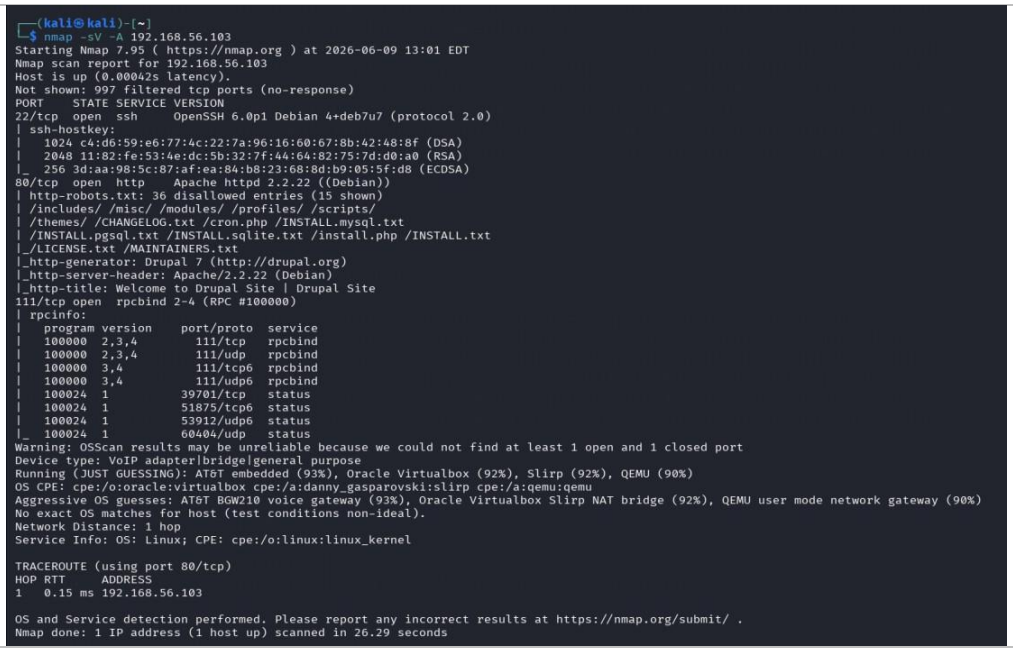


Figure 4.2 — Service fingerprint confirming an exploitable Drupal 7 build

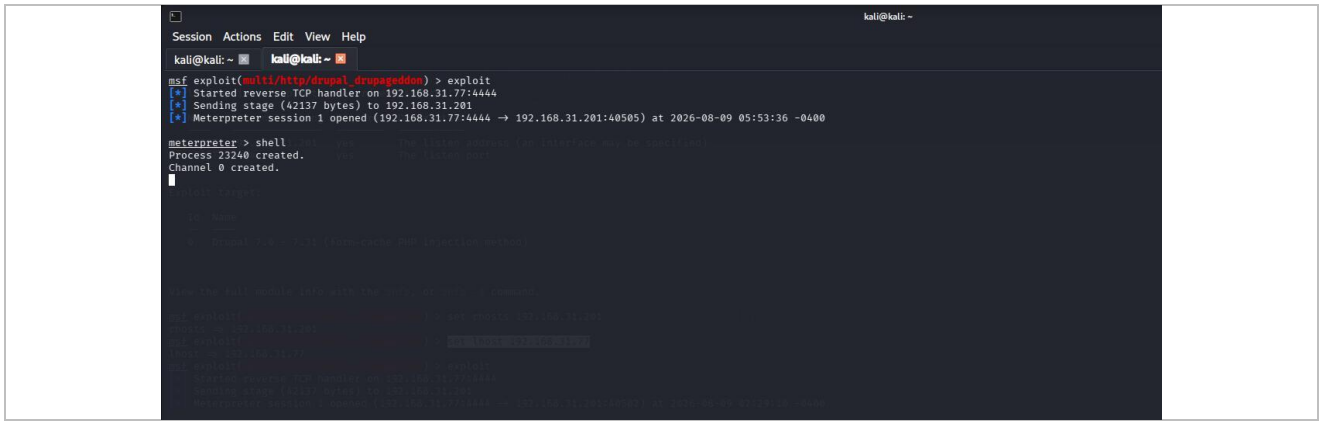


Figure 4.3 — Unauthenticated remote code execution yielding an interactive shell

Step 3 — Privilege Escalation

Enumeration from the web-server shell recovered database credentials from an exposed configuration file, and separately identified a locally-exploitable SUID binary. The SUID misconfiguration was leveraged directly to obtain a root-owned shell, completing full compromise of the host.

Full technical detail and evidence for each stage of this chain is documented under Findings PT-01 through PT-04 below.

5. Findings

Findings are ordered by severity. Each entry documents the affected component, technical evidence gathered during testing, the resulting business impact, and a specific remediation Mitigation.

5.1 Unauthenticated Remote Code Execution in Drupal (Drupalgeddon2)

PT-01	Unauthenticated Remote Code Execution in Drupal (Drupalgeddon2)	CRITICAL	CVSS 9.8

Affected Component: Drupal 7 core (CVE-2018-7600)

Description

The target's Drupal installation was an unpatched Drupal 7 build vulnerable to Drupalgeddon2, a defect in Drupal's Form API that allows crafted requests to inject and execute arbitrary PHP without any authentication. The vulnerability was confirmed against public advisories and successfully weaponised using the Metasploit Framework, returning an interactive shell in the web-server security context.

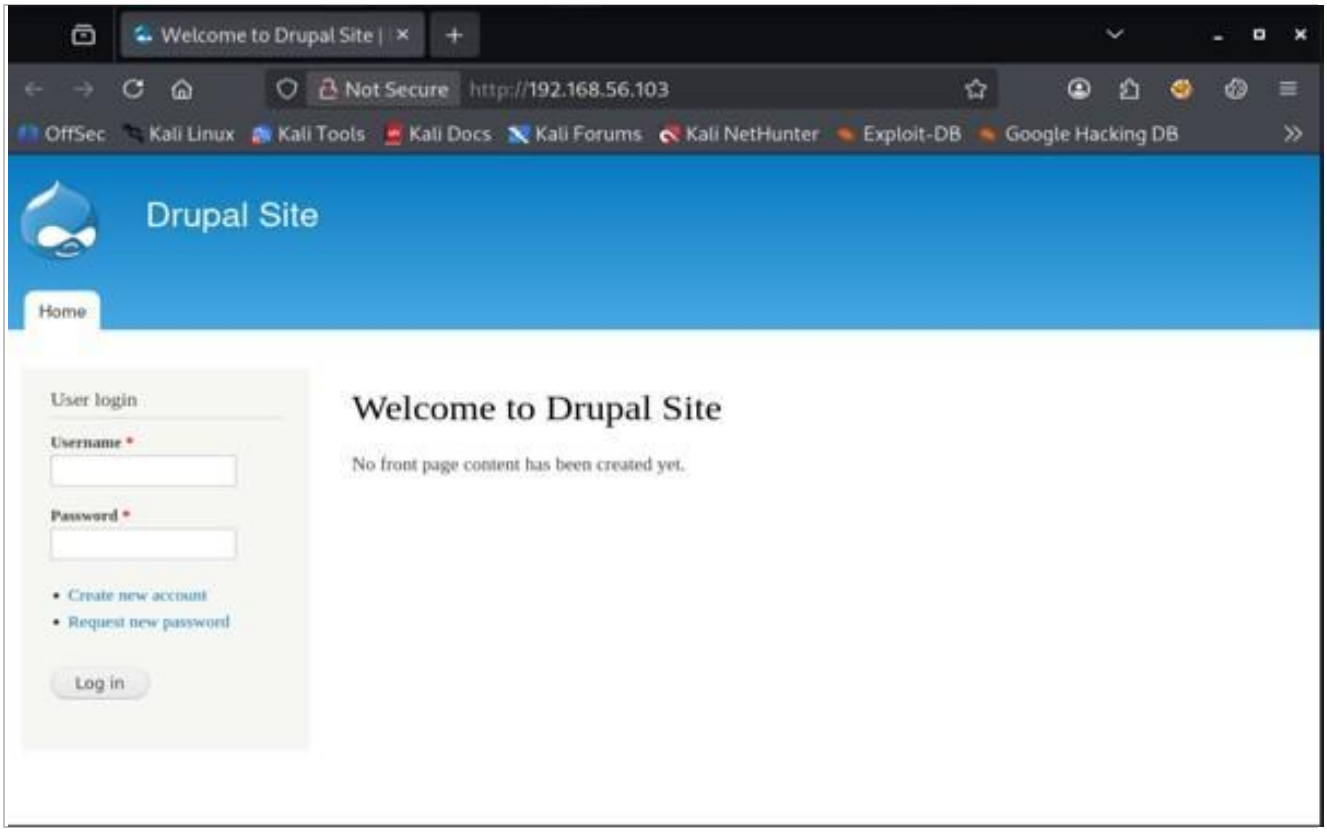


Figure 5.1 — Drupal landing page confirming the vulnerable CMS

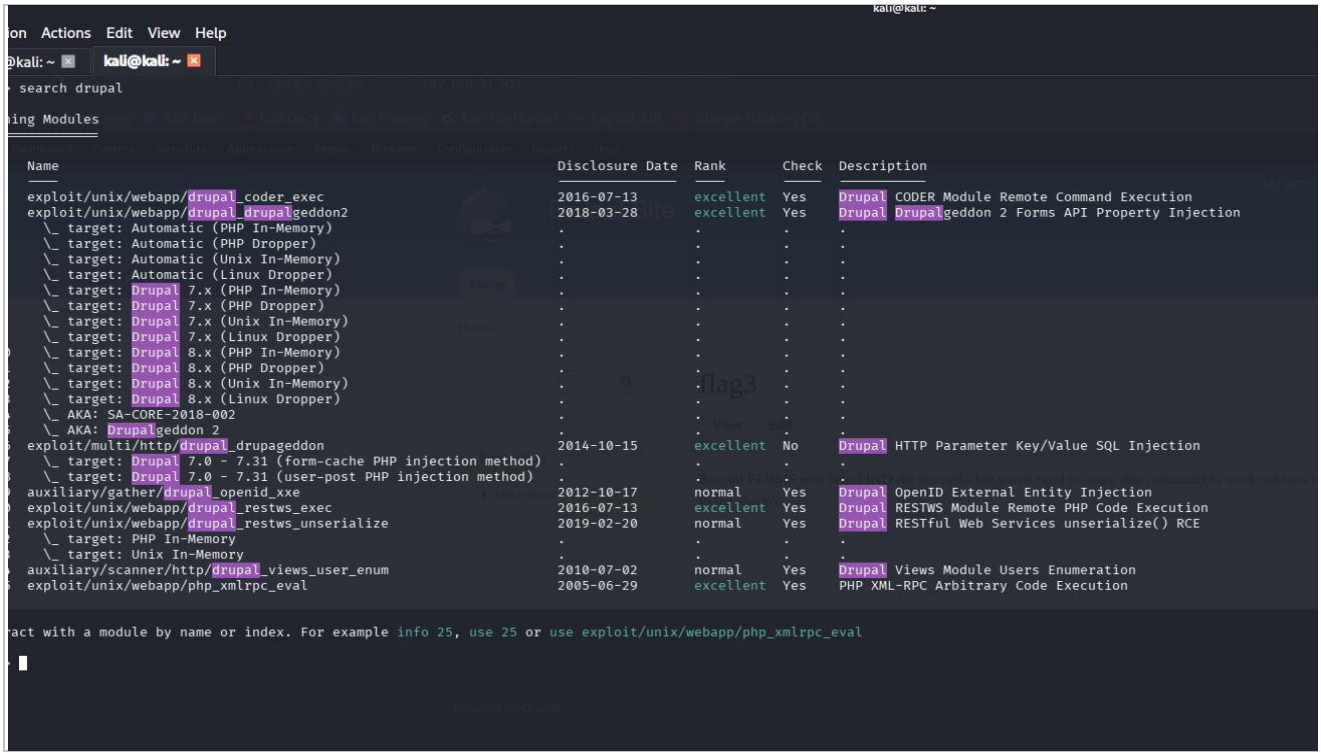


Figure 5.2 — Matching Metasploit exploit module identified

Business Impact

An external attacker requires no credentials to fully compromise the web application and pivot into the underlying host — the single most severe exposure identified in this assessment.

Mitigation

Upgrade Drupal to the latest supported minor release (7.58+/8.5.1+ or later) and apply vendor security patches on a recurring schedule. Where upgrading is not immediately possible, deploy virtual patching via a web application firewall.

5.2 Sensitive Configuration File Exposure

PT-02	Sensitive Configuration File Exposure	HIGH	CVSS 7.5

Affected Component: settings.php (Drupal site configuration)

Description

Once shell access was obtained, the Drupal configuration file was found to be readable by the web-server account and stored database credentials in clear text, alongside other application settings that would assist an attacker in further compromising the environment.

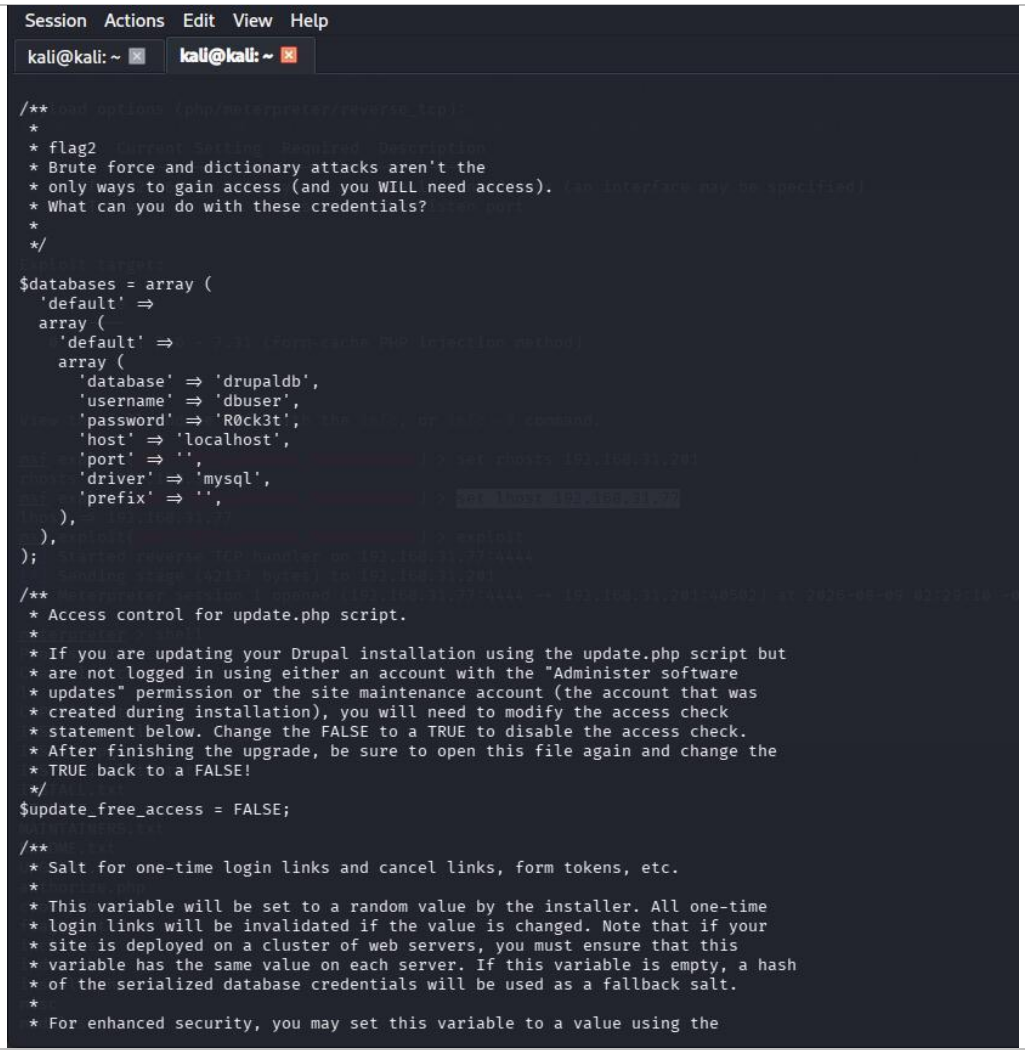


Figure 5.3 — settings.php disclosing live database credentials

Business Impact

Any process or user able to read this file — including a compromised web application — gains direct access to the backend database.

Mitigation

Restrict configuration-file permissions to the minimum accounts that require them, and migrate credentials to an encrypted secrets manager rather than storing them in application code.

5.3 Database Credential Disclosure & Unauthorized Data Access

PT-03	**Database Credential Disclosure & Unauthorized Data Access**	**HIGH**	**CVSS 8.1**

Affected Component: MySQL / MariaDB backend (drupaldb)

Description

The credentials recovered from the exposed configuration file were valid and provided direct interactive access to the Drupal database, including the full users table with stored password hashes and account metadata.

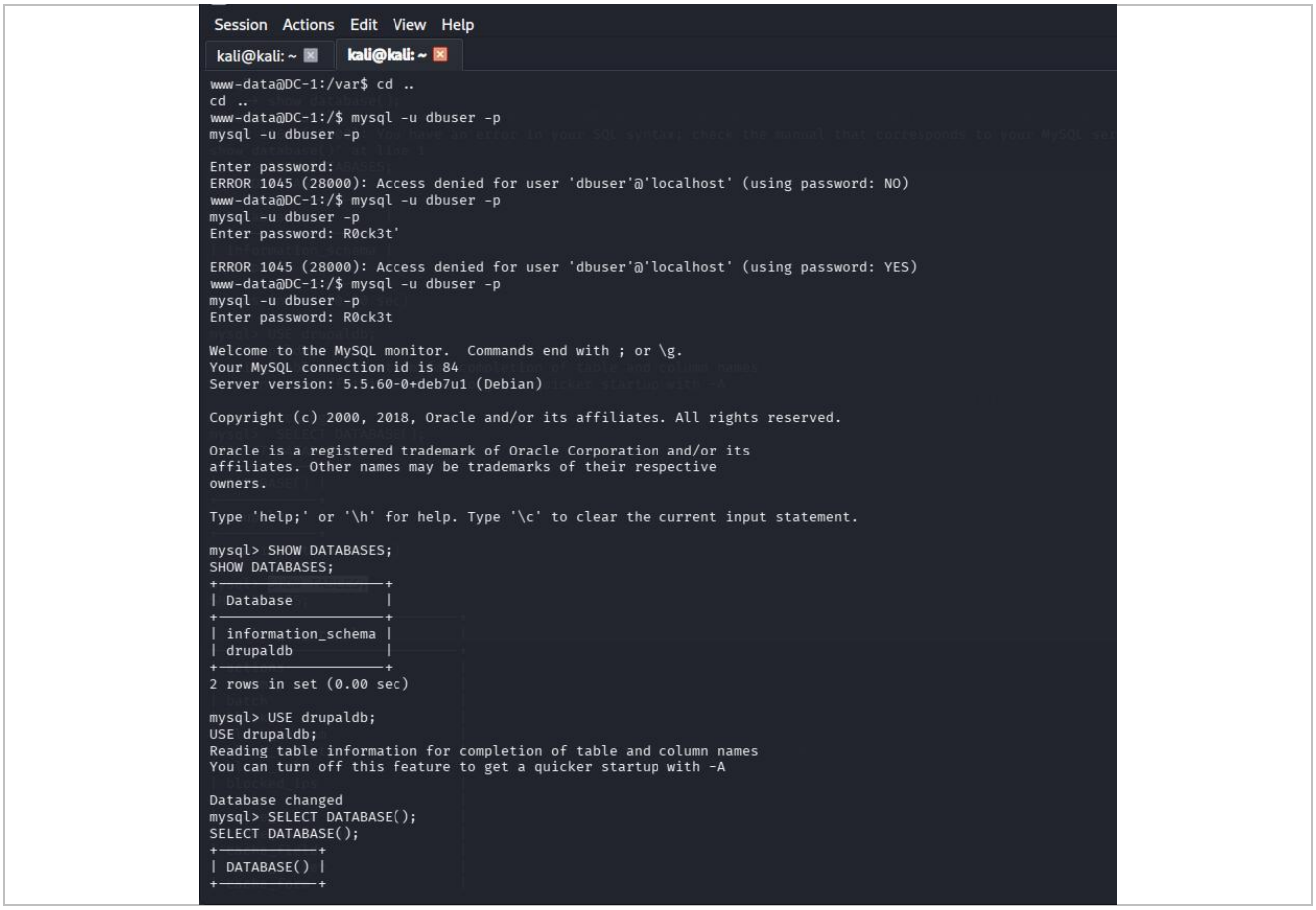


Figure 5.4 — Authenticated MySQL session using recovered credentials



Figure 5.5 — Dump of the Drupal user's table

Business Impact

Exposure of the complete user table, including password hashes, creates a downstream risk of offline cracking and account takeover, and represents unauthorized access to sensitive application data.

Mitigation

Rotate all database credentials, enforce least-privilege database accounts scoped to the application's actual needs, and enable database-layer audit logging.

5.4 Privilege Escalation via SUID Misconfiguration

PT-04	Privilege Escalation via SUID Misconfiguration	CRITICAL	CVSS 9.1

Affected Component: Local filesystem permissions (SUID binaries)

Description

Enumeration of the filesystem from the low-privileged web-server shell identified a binary with the SUID bit set that could be invoked to spawn a command shell running with root privileges, with no additional authentication required.

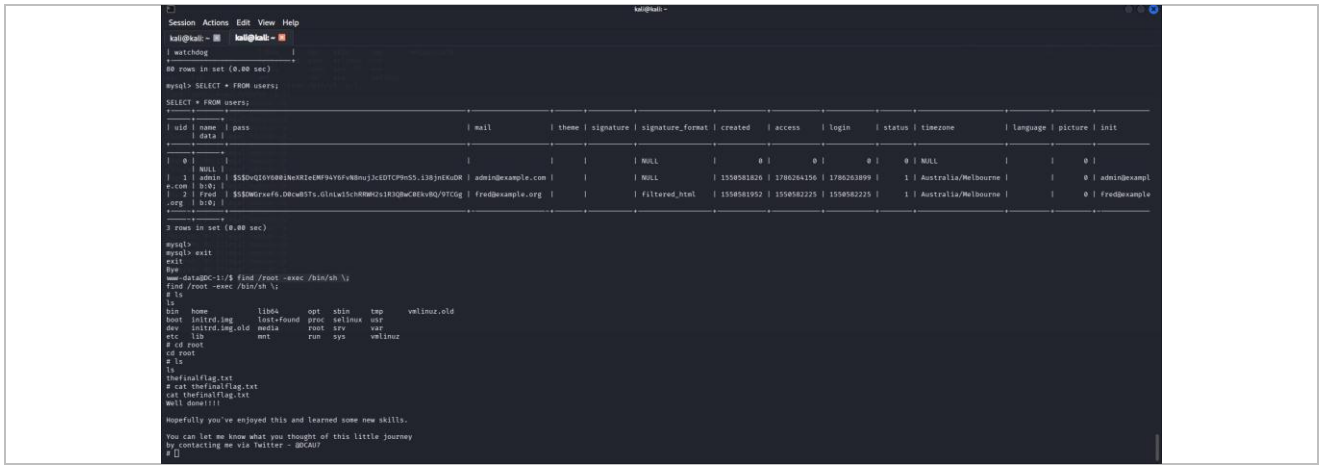


Figure 5.6 — SUID binary abused to obtain a root-owned shell

Business Impact

This finding converts any initial foothold, however limited, into complete operating-system compromise — the decisive step that turned a web-application bug into total loss of the host.

Mitigation

Audit all SUID/SGID binaries on production hosts, remove the bit from any binary that does not strictly require it, and monitor for its reintroduction via configuration-management drift detection.

5.5 Weak Authentication & Password Storage

PT-05	Weak Authentication & Password Storage	MEDIUM	CVSS 5.3

Affected Component: Drupal user accounts

Description

Recovered account records showed no evidence of additional authentication controls (such as multi-factor authentication or account lockout) protecting privileged accounts, increasing the value of the credential data disclosed in PT-03.

Business Impact

In combination with PT-03, weak authentication controls increase the likelihood that disclosed hashes could be cracked and reused to gain legitimate access.

Mitigation

Enforce strong password policies, enable account lockout thresholds, and add multi-factor authentication for administrative accounts.

5.6 Sensitive Information Disclosure via Unrestricted File Access

PT-06	Sensitive Information Disclosure via Unrestricted File Access	MEDIUM	CVSS 5.5

Affected Component: Filesystem and Drupal content nodes

Description

Multiple marker files were readable by the web-server account and, separately, sensitive content was viewable through the authenticated Drupal admin interface without further access control, indicating inconsistent handling of sensitive data throughout the application stack.

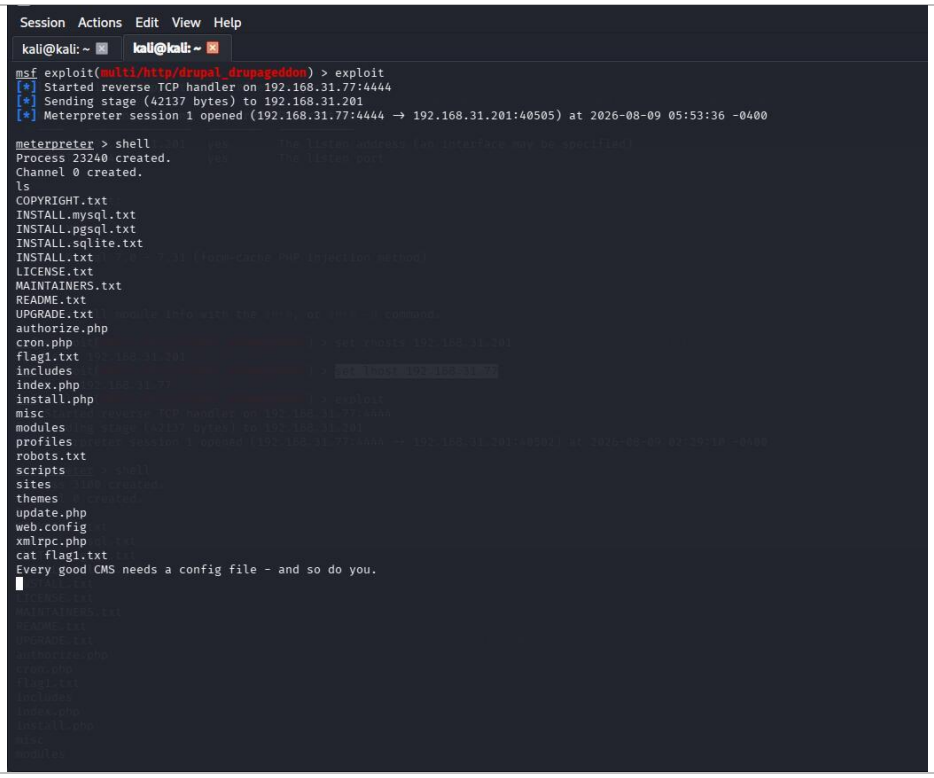


Figure 5.7 — Sensitive marker file readable from the compromised shell

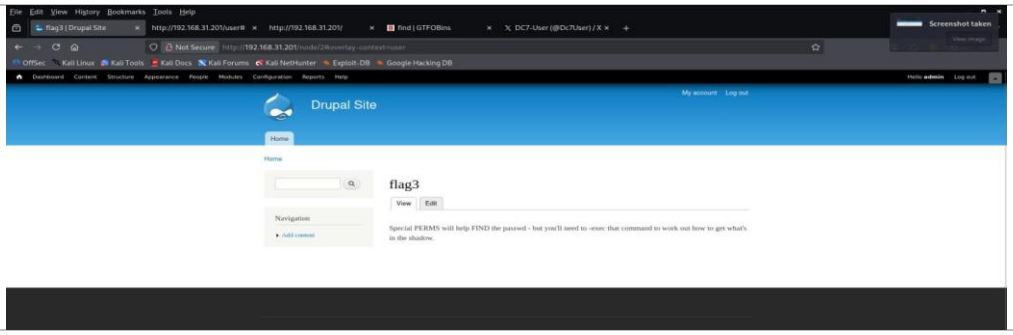


Figure 5.8 — Sensitive content exposed via the Drupal admin panel

Business Impact

Inconsistent access controls around sensitive files and content assist an attacker during post-exploitation and may expose data beyond what the application intends to disclose.

Mitigation

Apply consistent, least-privilege file permissions across the application directory tree and review content-level access controls within Drupal.

5.7 Unnecessary Service Exposure

PT-07	Unnecessary Service Exposure	LOW	CVSS 4.3

Affected Component: Network services (SSH, HTTP, RPC/rpcbind)

Description

The full port scan showed SSH, HTTP and RPC-related services reachable on the host. While not independently exploited in this engagement, each exposed service increases the available attack surface and the opportunities for enumeration.

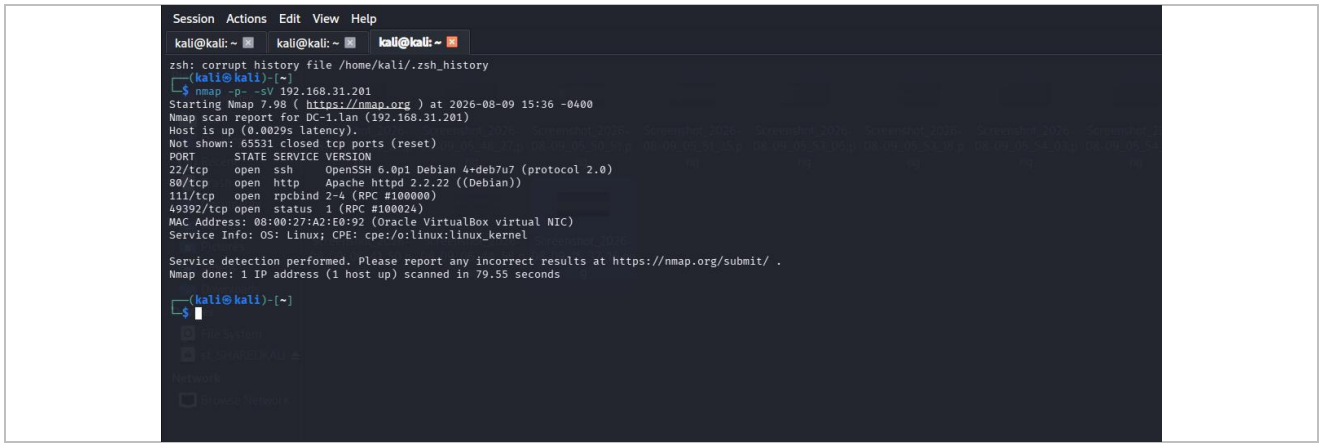


Figure 5.9 — Full-port scan showing all externally reachable services

Business Impact

A larger attack surface gives an adversary more potential entry points and increases the effort required for defenders to monitor the host comprehensively.

Mitigation

Disable or firewall any service not required for the host's function, and apply network segmentation to limit reachability from untrusted networks.

6. Remediation

Recommended remediation activity, prioritised by urgency and mapped to the findings it addresses:

Action	Related Finding(s)
Patch Drupal to a supported release; rotate all database credentials	PT-01, PT-02, PT-03
Remove unnecessary SUID bits and audit privileged binaries	PT-04
Introduce MFA and account-lockout policies for privileged accounts	PT-05
Normalise file and content access controls across the application	PT-06
Reduce exposed network services and apply segmentation	PT-07
Establish a recurring patch-management and vulnerability-scanning cadence	All

7. Conclusion

This engagement met its objective of determining how far an attacker could progress against DC-1 without prior credentials. A single unpatched CMS vulnerability was sufficient to obtain an initial foothold, and a local privilege-escalation flaw converted that foothold into complete root-level control within a short, uninterrupted session.

None of the individual weaknesses identified is unusual in isolation; the risk here comes from the ease with which they chained together in the absence of patching, credential hygiene, and file-permission hardening. Addressing the items in the Section 6 roadmap — beginning with the two Critical findings — would have closed off every path used during this assessment.

Viewed end to end, PT-01 supplied the initial foothold, PT-02/PT-03 turned it into working database credentials, PT-05/PT-06/PT-07 offered little resistance along the way, and PT-04 converted that access into full root ownership — a single continuous chain rather than seven unrelated bugs, rooted in three recurring gaps: missed patching, poor credential hygiene, and weak file-permission hardening. What stands out is how little the attack required to succeed: one tester, public advisories, open-source tooling, and under three hours from first packet to root shell, with no detective or alerting control intervening at any stage — a gap between lab and production risk that's easy to underestimate. Closing the Section 6 roadmap would eliminate every finding in this report, but because a single missed update was enough to enable it all, remediation should be treated as ongoing — a recurring patch cadence and periodic re-testing are what keep these fixes from quietly eroding over time.

8. Appendix A — Tooling

Phase	Tools Used
Reconnaissance	arp-scan, netdiscover, Nmap
Exploitation	Metasploit Framework
Post-Exploitation	Native Linux enumeration utilities, MySQL client

9. Appendix B — Tester Environment

For reproducibility, the attacking workstation's network configuration at the time of testing is recorded below.

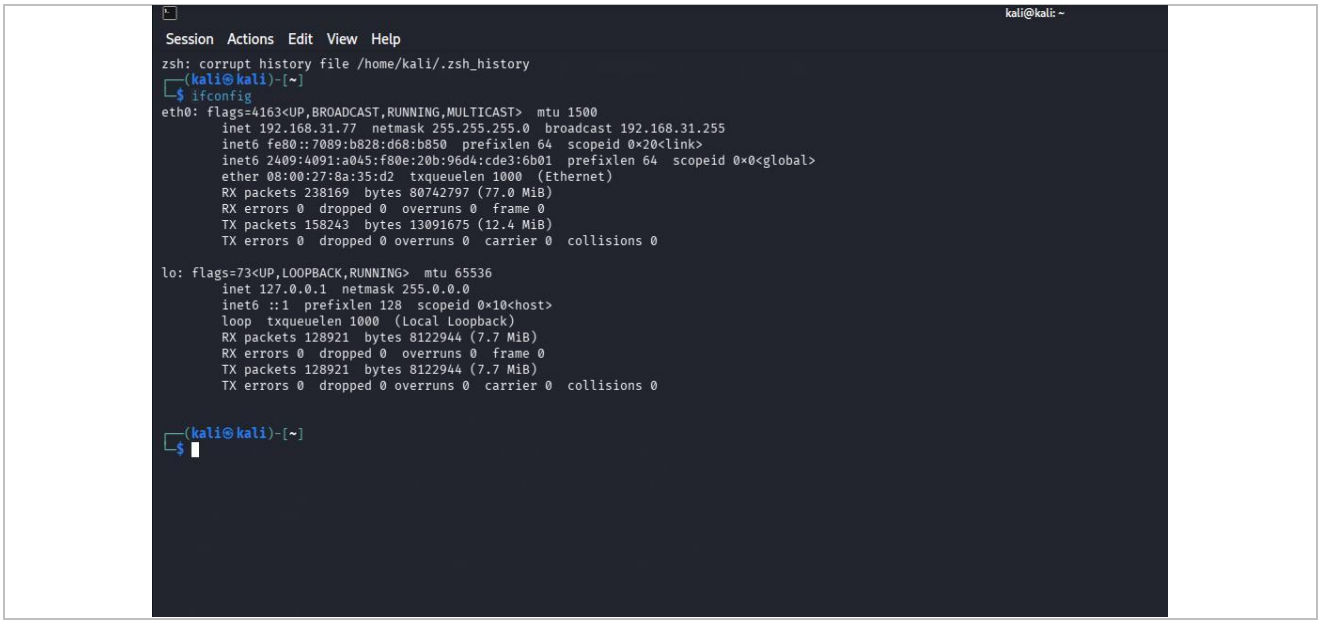


Figure B.1 — Attacking workstation network interface configuration